

Report configurazione DVWA

Obiettivo

L'obiettivo dell'esercitazione è stato configurare DVWA su Kali Linux, creando un ambiente di laboratorio locale per lo studio delle vulnerabilità delle applicazioni web.

Nella seconda parte è stato utilizzato Burp Suite per intercettare, modificare e ripetere le richieste HTTP generate dall'applicazione durante il processo di autenticazione.

Installazione e configurazione di DVWA

Per iniziare è stata aperta una sessione di terminale con privilegi di amministratore tramite:

- `sudo su`

Successivamente è stata raggiunta la directory utilizzata da Apache per ospitare i file web:

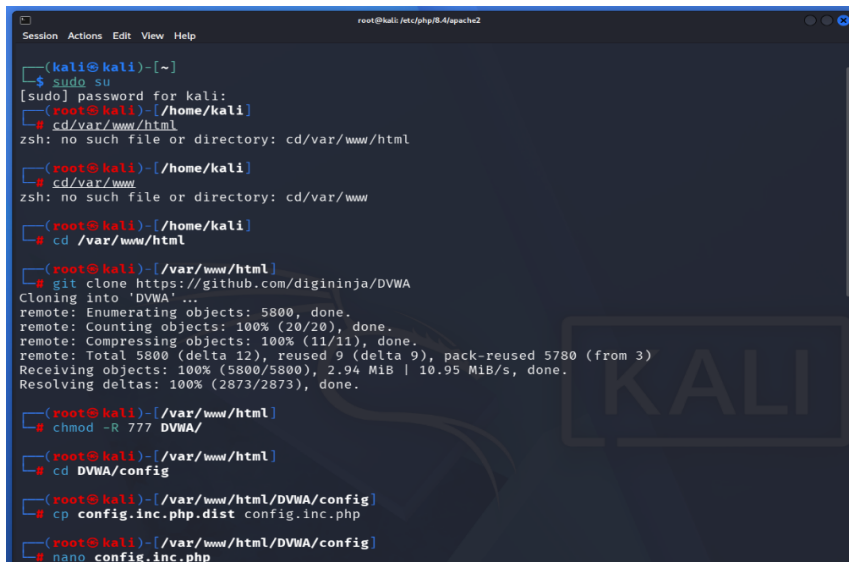
- `cd /var/www/html`

DVWA è stata scaricata tramite Git:

- `git clone https://github.com/digininja/DVWA`

Sono stati successivamente modificati i permessi della directory:

- `chmod -R 777 DVWA/`



```
root@kali: /etc/php/8.1/apache2
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# cd /var/www/html
zsh: no such file or directory: cd/var/www/html

(root@kali)-[/home/kali]
# cd /var/www
zsh: no such file or directory: cd/var/www

(root@kali)-[/home/kali]
# cd /var/www/html

(root@kali)-[/var/www/html]
# git clone https://github.com/digininja/DVWA
Cloning into 'DVWA'...
remote: Enumerating objects: 5800, done.
remote: Counting objects: 100% (20/20), done.
remote: Compressing objects: 100% (11/11), done.
remote: Total 5800 (delta 12), reused 9 (delta 9), pack-reused 5780 (from 3)
Receiving objects: 100% (5800/5800), 2.94 MiB | 10.95 MiB/s, done.
Resolving deltas: 100% (2873/2873), done.

(root@kali)-[/var/www/html]
# chmod -R 777 DVWA/

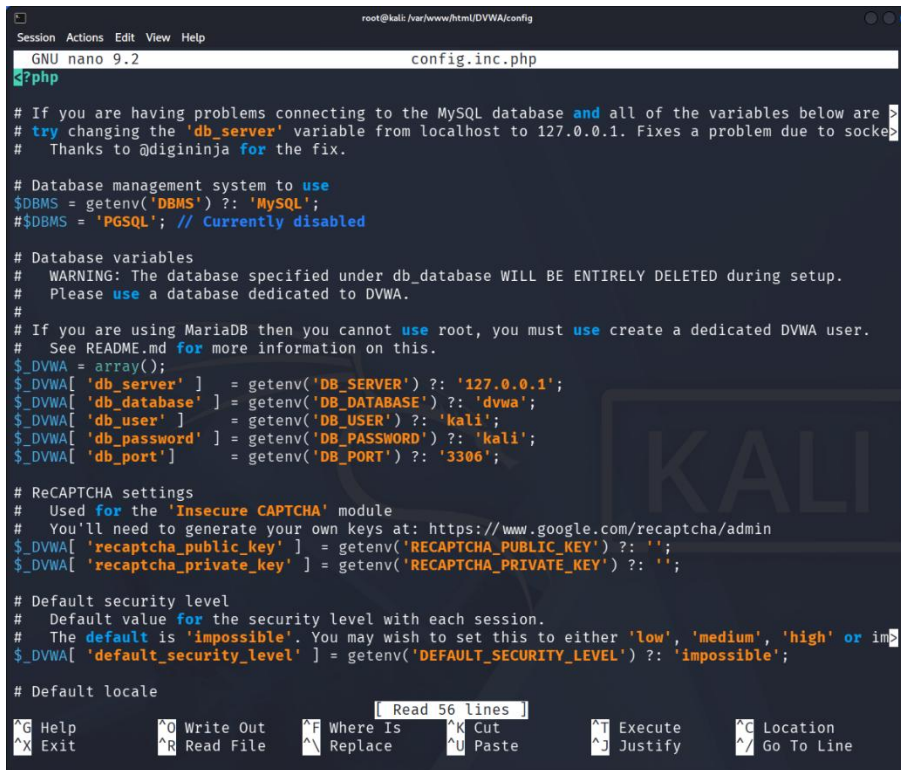
(root@kali)-[/var/www/html]
# cd DVWA/config
(root@kali)-[/var/www/html/DVWA/config]
# cp config.inc.php.dist config.inc.php

(root@kali)-[/var/www/html/DVWA/config]
# nano config.inc.php
```

È stata poi aperta la cartella dell'applicazione e creato il file di configurazione partendo dal modello fornito:

- cd DVWA
- cp config/config.inc.php.dist config/config.inc.php

Il file di configurazione è stato modificato tramite un editor di testo, inserendo le credenziali utilizzate per la connessione al database.



```
root@kali: /var/www/html/DVWA/config
GNU nano 9.2 config.inc.php

# If you are having problems connecting to the MySQL database and all of the variables below are
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to socke
# Thanks to @digininja for the fix.

# Database management system to use
$dbms = getenv('DBMS') ?: 'MySQL';
#$dbms = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA['db_user'] = getenv('DB_USER') ?: 'kali';
$_DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'kali';
$_DVWA['db_port'] = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
# Used for the 'Insecure CAPTCHA' module
# You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$_DVWA['recaptcha_public_key'] = getenv('RECAPTCHA_PUBLIC_KEY') ?: '';
$_DVWA['recaptcha_private_key'] = getenv('RECAPTCHA_PRIVATE_KEY') ?: '';

# Default security level
# Default value for the security level with each session.
# The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or im
$_DVWA['default_security_level'] = getenv('DEFAULT_SECURITY_LEVEL') ?: 'impossible';

# Default locale
Read 56 lines
^G Help      ^O Write Out ^F Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^N Replace   ^U Paste     ^J Justify   ^_ Go To Line
```

Configurazione del database MySQL

Successivamente è stato avviato il servizio MySQL:

È stato effettuato l'accesso al database utilizzando l'utente root:

- mysql -u root -p

All'interno di MySQL è stato creato un nuovo utente dedicato a DVWA:

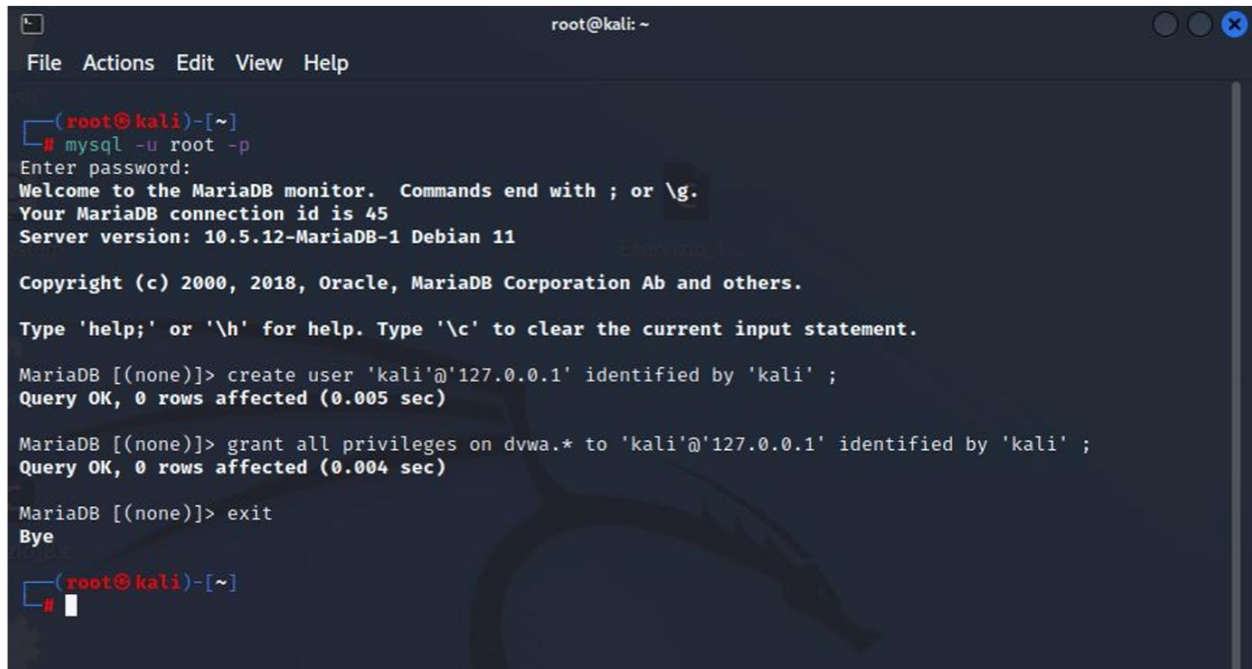
create user 'kali'@'127.0.0.1' identified by 'kali';

Sono stati quindi assegnati i privilegi necessari sul database DVWA:

```
grant all privileges on dvwa.* to 'kali'@'127.0.0.1' identified by 'kali';
```

Terminata la configurazione, si è usciti dalla console MySQL tramite:

```
exit
```



```
root@kali: ~  
File Actions Edit View Help  
(root@kali)~[~]  
# mysql -u root -p  
Enter password:  
Welcome to the MariaDB monitor. Commands end with ; or \g.  
Your MariaDB connection id is 45  
Server version: 10.5.12-MariaDB-1 Debian 11  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
MariaDB [(none)]> create user 'kali'@'127.0.0.1' identified by 'kali' ;  
Query OK, 0 rows affected (0.005 sec)  
MariaDB [(none)]> grant all privileges on dvwa.* to 'kali'@'127.0.0.1' identified by 'kali' ;  
Query OK, 0 rows affected (0.004 sec)  
MariaDB [(none)]> exit  
Bye  
(root@kali)~[~]  
#
```

Configurazione di PHP e Apache

Per configurare PHP è stata raggiunta la directory relativa ad Apache:

```
- cd /etc/php/8.4/apache2
```

Successivamente è stato modificato il file php.ini, intervenendo sulle impostazioni:

```
allow_url_fopen = On
```

```
allow_url_include = On
```

Dopo aver completato la configurazione, è stato avviato il servizio Apache:

```
service apache2 start
```

Configurazione tramite browser

Per verificare il corretto funzionamento dell'applicazione è stato aperto il browser e inserito il seguente indirizzo:

127.0.0.1/DVWA/setup.php

Dalla pagina di configurazione è stata utilizzata l'opzione Create / Reset Database, che ha permesso di creare il database necessario al funzionamento dell'applicazione.

Completata questa operazione, è stata visualizzata la pagina di login di DVWA. Per accedere sono state utilizzate le credenziali predefinite:

Username: admin

Password: password

Dopo aver effettuato l'accesso, è stata aperta la sezione DVWA Security. Il livello di sicurezza dell'applicazione è stato impostato su Low.

Analisi con Burp Suite

Nella seconda parte dell'esercitazione è stato avviato Burp Suite, selezionando un progetto temporaneo.

È stato quindi aperto il browser e raggiunto l'indirizzo:

127.0.0.1/DVWA

È stato effettuato un tentativo di login utilizzando inizialmente le credenziali:

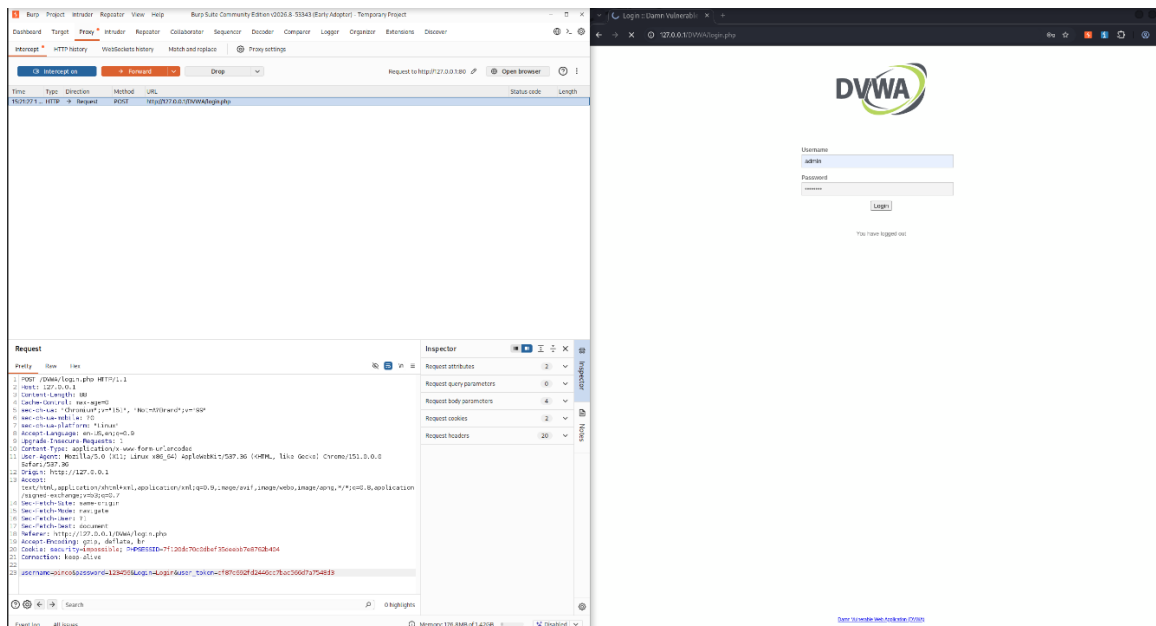
Username: admin

Password: password

La richiesta HTTP generata dal browser è stata intercettata tramite Burp Suite. In questo modo è stato possibile visualizzare i parametri inviati all'applicazione e modificarli prima dell'invio.

La richiesta è stata inviata al Repeater tramite l'opzione Send to Repeater. Questo strumento permette di modificare e inviare nuovamente la stessa richiesta più volte.

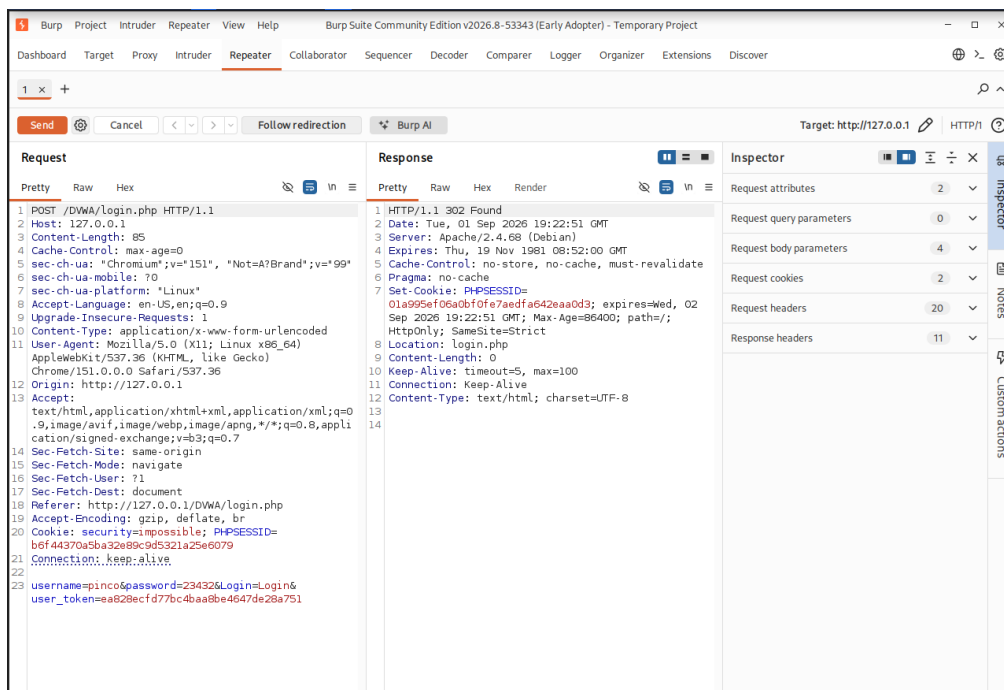
Sono state quindi inserite credenziali volutamente errate e la richiesta è stata inviata tramite il pulsante Send.



Nel body della risposta è stato visualizzato il messaggio:

Login failed

Questo ha confermato che le credenziali modificate non erano valide e ha permesso di osservare direttamente il rapporto tra la richiesta inviata dal client e la risposta restituita dal server.



Conclusione

L'esercitazione ha permesso di configurare un ambiente DVWA funzionante su Kali Linux, comprendendo il ruolo di Apache, MySQL e PHP nel funzionamento dell'applicazione.